ASEGURAMIENTO DE CALIDAD

Prueba del TP Obligatorio

Plan, trazabilidad, ejecución, defectos, seguridad y uso de IA

Dato	Valor
Grupo / dominio	Grupo 5 · Obras Públicas, Infraestructura y Mantenimiento Urbano
Versión candidata	v1.0-testing (tag pendiente de crear sobre main luego de cerrar todos los gates)
Fecha límite documental	10/11/2026, 13:30 — carga en Teams por QA
Repositorios	TPO / DesarrolloDeAplicacionesIIBack / DesarrolloAppsII_Front
Ambientes	Local reproducible; Azure Test para demo; Core compartido para integración bilateral
Responsables	QA: completar · DevOps: Tomás Gramajo · Front/Back: completar nombres

Estado global: NO APTO TODAVÍA PARA ETIQUETAR. Hay evidencia local favorable, pero quedan condiciones eliminatorias que deben cerrarse y registrarse.

Este informe no reemplaza Jira, Teams ni la demo en vivo. Los campos "pendiente" deben completarse con enlaces y capturas reales antes de la entrega.

1. Dictamen ejecutivo y condiciones eliminatorias

La regla operativa es binaria: si una condición G1–G9 no tiene evidencia válida, la instancia puede quedar desaprobada. La tabla distingue hechos verificados de tareas preparadas o pendientes.

Gate	Criterio	Estado	Evidencia / acción
G1	Clon limpio + un comando ≤15 min	PREPARADO / NO EJECUTADO	compose.yaml y .env.example creados; falta corrida cronometrada desde clon limpio con Docker Desktop.
G2	Tag v1.0-testing en main antes de 13:30	PENDIENTE	Crear únicamente después de fusionar y comprobar CI; capturar URL, SHA y hora.
G3	CI completo en verde sobre el tag	PARCIAL	CI remoto de Front y Back aprobado y fusionado; falta repetirlo sobre el commit/tag final v1.0-testing.
G4	Entregables QA en Teams	PENDIENTE	Este documento integra los mínimos; QA debe completar enlaces/evidencias y cargarlo antes del límite.
G5	Jira actualizado	PENDIENTE	Crear/actualizar casos y defectos con HU, dueño, severidad, estado y evidencia.
G6	Cero secretos en toda la historia	PARCIAL	Gitleaks aprobó los PR; falta ejecutar y conservar evidencia del escaneo de toda la historia sobre el tag.
G7	Demo E2E en vivo	PENDIENTE	Existe recorrido histórico en Azure; debe repetirse en vivo sobre v1.0-testing.
G8	Declaración de IA completa	BORRADOR	Sección 10 preparada; cada integrante debe validar, completar herramientas/prompts y firmar revisión.
G9	Informe honesto	CUMPLE EN BORRADOR	Las brechas se mantienen visibles; no se declaran aprobadas pruebas sin evidencia.

Decisión de salida

- No crear el tag mientras G1, G3 y G6 no hayan pasado sobre el commit candidato.
- No cargar el PDF en Teams sin enlaces de Jira, CI, Quality Gate, seguridad y evidencias de ejecución.
- No ocultar defectos: 0 Blocker, 0 Critical y máximo 3 Major con workaround es el umbral de aceptación.

2. Estrategia y plan de pruebas

2.1 Alcance

- Incluido: autenticación multirol; proyectos; órdenes de trabajo; recursos; cortes; persistencia PostgreSQL; API REST; proxy /api; seguridad por roles; eventos M2/M6/M7/M1; Outbox/Inbox y tolerancia de mensajería.
- Incluido: Front responsivo a 360, 768 y 1280 px; manejo de errores; accesibilidad; performance; análisis de dependencias y secretos.
- Fuera del resultado ejecutado actual: integración bilateral real con todos los módulos, pruebas k6, ZAP, mutación PIT, Sonar y Testcontainers, hasta producir evidencia.

2.2 Niveles, ambientes y datos

Nivel	Ambiente	Objetivo	Datos
Unitario	CI / local	Reglas, estados, validadores, componentes y clientes	Factories y fixtures sin datos personales
Integración	Docker local	PostgreSQL, API, proxy y broker disponible	Seed reproducible y cuentas demo
Contrato	CI / Core	Envelope y data contra JSON Schema/OpenAPI	UUID v4 y payloads ficticios
E2E	Azure Test	Cinco recorridos automatizados + demo manual	Proyecto, OT y corte QA identificables
Resiliencia	Docker / Core coordinado	Broker/externo caído, duplicados, DLQ y recuperación	eventId/correlationId registrados
Seguridad	CI / Test	OWASP API, authn/authz, ZAP, SCA y secretos	Tokens efímeros; nunca se adjuntan
Performance	Test controlado	50 usuarios, 5 min, 3 endpoints críticos	Datos precreados; sin mutar producción

2.3 Entrada y salida

Entrada	Salida
Código fusionado en main; .env local válido; Docker/CI disponibles; schemas versionados; datos ficticios; defectos conocidos cargados.	G1–G9 aprobados; 100% HU ejecutadas; ≥95% CA aprobados; 0 Blocker/Critical; ≤3 Major con workaround; CI verde; evidencias enlazadas; demo ensayada.

2.4 Matriz de riesgos priorizada

ID	Riesgo	Prob.	Impacto	Nivel	Tratamiento
R-01	Arranque no reproducible	Alta	Alta	Crítico	Clon limpio cronometrado; fail-fast de .env
R-02	Autorización horizontal/vertical	Alta	Alta	Crítico	BOLA/BFLA multirol + 401/403
R-03	Pérdida/duplicado de eventos	Alta	Alta	Crítico	Inbox/Outbox, eventId, ACK/NACK, DLQ
R-04	Transición de estado inválida	Media	Alta	Alto	Tabla de estados y respuesta 409
R-05	Corte o módulo externo caído	Media	Alta	Alto	Timeout, circuit breaker/fallback, recuperación
R-06	Secreto en Git/log	Media	Alta	Crítico	Gitleaks histórico y revisión de logs
R-07	UI no usable/accesible	Media	Media	Medio	Viewport + axe/Lighthouse
R-08	Degradación de rendimiento	Media	Media	Medio	k6 y límites p95/error

3. Matriz de trazabilidad

HU	Criterios	Casos	Automatización	Resultado	Evidencia	Defecto
HU-01 Login	CA-01 happy / CA-02 inválido / CA-03 rol	TC-001/002/003	Front App.test + Back AuthController	Local: PASS	coverage + surefire	—
HU-02 Proyecto	CA-04 crear / CA-05 aprobar / CA-06 rechazar	TC-004/005/006	ProjectController/Service tests	Local: PASS parcial	JaCoCo	DEF-PEND
HU-03 Orden	CA-07 crear / CA-08 transición / CA-09 error	TC-007..011	WorkOrder tests	Local: PASS	JaCoCo	—
HU-04 Recursos	CA-10 asignar / CA-11 stock / CA-12 conflicto	TC-012/013/014	Resource tests	Local: PASS parcial	Surefire	DEF-PEND
HU-05 Corte	CA-13 solicitar / CA-14 aprobar / CA-15 vencer	TC-015/016/017	StreetClosure tests	Local: PASS parcial	JaCoCo	INT-M7
HU-06 M2	CA-16 ROUTED / CA-17 RESOLVED / CA-18 inválido	TC-018/019/020	Message consumer tests	Local: PASS parcial	Surefire	INT-M2
HU-07 M6	CA-19 request / CA-20 schedule / CA-21 complete	TC-021/022	Schema + handlers	Pendiente E2E	Core event log	INT-M6
HU-08 Resiliencia	CA-22 broker down / CA-23 duplicate / CA-24 DLQ	TC-023/024	Inbox/Outbox tests	Local: PASS parcial	logs/DB	INT-CORE

Antes de entregar: reemplazar “parcial/pendiente” por el resultado real y una URL o ruta exacta. El profesor debe poder recorrer HU → CA → caso → automatización → resultado → evidencia → defecto.

4. Especificación de casos

ID	Caso	Precond.	Datos	Pasos	Esperado	Prio	Tipo	Auto
TC-001	Login válido por cada rol	Usuarios seed	Usuario + DEMO_PASSWORD	Ingresar; verificar menú y permisos	200, token y UI del rol	P0	F+S	Sí
TC-002	Password incorrecta	Usuario existente	Password inválida	Intentar login	401 sin filtrar detalles	P0	N	Sí
TC-003	JWT expirado/manipulado/alg none	Token preparado	3 tokens inválidos	Invocar endpoint protegido	401 en los tres	P0	N+S	Pend.
TC-004	Crear y presentar proyecto	PERSONAL_OBRAS	Proyecto QA	Crear; editar; presentar	Estado pendiente y datos persistidos	P0	F	Sí
TC-005	Presupuesto negativo	Sesión válida	-1	Crear proyecto	400 Problem Details; sin alta	P0	N	Sí
TC-006	Aprobar sin rol	OPERARIO	projectId válido	Aprobar	403; estado intacto	P0	N+S	Sí
TC-007	Crear OT desde proyecto	Proyecto aprobado	UUID + número visible	Crear OT	OT vinculada una vez	P0	F	Sí
TC-008	Proyecto inexistente	Sesión válida	UUID inexistente	Crear OT	404; sin alta	P0	N	Sí
TC-009	Transición programar→iniciar→completar	OT creada	Fechas válidas	Ejecutar flujo por roles	Estados y auditoría correctos	P0	F	Sí
TC-010	Transición inválida	OT completada	Acción start	Intentar iniciar	409 Problem Details	P0	N+B	Pend.
TC-011	Reabrir y validar	OT completada	Motivo + evidencia	Inspector reabre; se completa; valida	Historial íntegro	P0	F	Sí
TC-012	Asignar recurso disponible	OT programada	Cuadrilla	Asignar	Carga y vínculo actualizados	P1	F	Parcial
TC-013	Stock insuficiente	Material bajo	Cantidad > stock	Asignar	409; sin stock negativo	P0	N+B	Pend.
TC-014	Concurrencia/ETag obsoleto	Dos clientes	ETag viejo	Actualizar desde ambos	Segundo recibe 412	P1	N+R	Pend.
TC-015	Solicitar corte estructurado	OT válida	affectedSections	Solicitar	Evento v1.0 válido	P0	F+I	Parcial
TC-016	Corte rechazado	Solicitud emitida	streetClosureRejected	Consumir evento	Estado rechazo y motivo	P0	A+I	Parcial
TC-017	Corte vence	ACTIVE/APROVED	endDate vencido	Avanzar reloj	ACTIVE ended; APPROVED expired	P1	B+I	Pend.
TC-018	ticketUpdated no M3	Consumidor activo	responsibleAreald M4	Consumir	ACK e ignorar sin mutación	P0	A+N	Parcial
TC-019	STARTED antes de PROGRESS	Ticket ROUTED	Dos eventos	Publicar en orden	M2 acepta ambos	P0	A+I	Pend.
TC-020	PROGRESS fuera de orden	Ticket ROUTED	PROGRESS	Publicar	NACK/DLQ según Core; sin inconsistencia	P0	A+N	Pend.
TC-021	requestId→sourceRequestId	M6/Core activos	UUID	Consumir request; emitir schedule/complete	Correlación preservada	P0	A+I	Pend.
TC-022	data omitido	Core disponible	Envelope sin data	POST /events	422 y no ingresa al hub	P0	N+C	Sí código
TC-023	Duplicado exacto	Inbox activa	Mismo eventId dos veces	Entregar dos veces	Una sola mutación; ACK seguro	P0	N+R	Parcial
TC-024	Broker caído y recuperación	Stack activo	Corte de broker	Detener; operar; reiniciar	Sin pérdida; Outbox reintenta	P0	N+R	Pend.

Cobertura negativa/borde: 11 de 24 casos (45,8%), superior al mínimo de 40%. Leyenda: F funcional, N negativo, B borde, S seguridad, I integración, A asíncrono, R resiliencia, C contrato.

5. Informe de ejecución

Corte de evidencia: Resultados locales y CI remoto del 03/11/2026. No equivalen todavía al arranque limpio, Test, Core bilateral ni demo en vivo.

5.1 Resultados verificados

Componente	Comando	Resultado	Cobertura / observación
Back	mvnw clean verify	105 tests PASS; JAR generado	Líneas 90,83%; ramas 70,67%; gate 80/70
Front	npm run test:coverage	58 tests PASS	Sent. 86,05%; ramas 77,81%; func. 84,09%; líneas 85,84%
Front	npm run lint / build	PASS	TypeScript/Vite y contenedor aprobados en CI; PR #14 fusionado a develop
Front SCA	npm audit --audit-level=high	Sin High/Critical	3 Moderate del tooling de desarrollo
Back	mvn clean verify	105 tests PASS	Cobertura: líneas 90,83%; ramas 70,67%; PR #15 fusionado a develop
Back CI	3 corridas + Gitleaks + Trivy + Docker	PASS	Dos ejecuciones verdes; sin secretos en el cambio ni High/Critical
Compose	docker compose config/up	NO EJECUTADO	Docker CLI no disponible en la estación de esta auditoría

5.2 Métricas obligatorias aún pendientes

Métrica	Umbral	Resultado	Evidencia requerida
Mutación dominio	≥60%	Pendiente	Reporte PIT/Stryker del commit etiquetado
Sonar Quality Gate	Approved	Pendiente	URL/captura; 0 blocker/critical; A; dup ≤3%; hotspots 100%
E2E pipeline	≥5	Pendiente	Job CI y artefactos Playwright/Cypress
Accesibilidad	≥90; 0 críticos	Pendiente	Lighthouse + axe 360/768/1280
Performance	p95 <500 ms; error <1%	Pendiente	k6 50 VU, 5 min, 3 endpoints
Flakiness	3 corridas idénticas	Aprobado en Front y Back	CI remoto verde; repetir sobre el tag final
Testcontainers	DB y broker reales	Pendiente	Pruebas CI con PostgreSQL/RabbitMQ containers

6. Registro de defectos

ID	Descripción	Sev.	Estado	Dueño	Reproducción / corrección	Jira
DEF-001	G1 no ejecutado desde clon limpio	Major	Preparado	QA/DevOps	Ejecutar y cronometrar; adjuntar log y captura	Pendiente Jira
DEF-002	Sin E2E automatizado en pipeline	Major	Abierto	Front/QA	Implementar ≥5 recorridos Playwright	Pendiente Jira
DEF-003	Sin mutación ni Sonar final	Major	Abierto	Back/DevOps	Configurar y conservar reportes	Pendiente Jira
DEF-004	Sin evidencia k6/ZAP/axe	Major	Abierto	QA	Ejecutar contra Test controlado	Pendiente Jira
DEF-005	Integración Core bilateral no acreditada	Major	Abierto	Back/DevOps	Coordinar eventId y registro de punta a punta	Pendiente Jira

El número de defectos Major abiertos excede el umbral de salida. Deben corregirse o reclasificarse únicamente con evidencia; no se deben ocultar para cumplir el máximo.

7. Seguridad

ID	Control	Prueba	Esperado	Estado
SEC-01	BOLA	Cambiar UUID de proyecto/OT entre usuarios	403/404 sin filtración	Pendiente
SEC-02	BFLA	Operario intenta aprobar/rechazar	403 y sin mutación	Parcial
SEC-03	JWT	Expirado, firma alterada, alg none, issuer incorrecto	401 uniforme	Pendiente

SEC-04	Mass assignment	Campos role/status/owner adicionales	Ignorados o 400	Pendiente
SEC-05	Injection/XSS	SQL/meta/caracteres y scripts	Sin ejecución/reflejo	Pendiente
SEC-06	XXE	XML con entidad externa si aplica	Rechazo seguro/no aplicable justificado	Pendiente
SEC-07	Brute force	Intentos repetidos de login	429 y política documentada	Pendiente
SEC-08	Headers/CORS	Origins y headers	CSP/HSTS/XCTO; CORS restrictivo	Pendiente
SEC-09	Secrets/logs	Gitleaks + inspección logs	0 secretos; 0 token/PII/stack trace	Gitleaks PR PASS; historia completa pendiente
SEC-10	SCA/ZAP	Escaneo dependencia y DAST	0 High; Medium justificado	Pendiente

Tratamiento de credenciales

- .env está ignorado; .env.example enumera variables sin valores reales.
- Compose corta con mensaje explícito si faltan DB_PASSWORD, JWT_SECRET, DEMO_PASSWORD o RABBITMQ_PASSWORD.
- Contraseñas/tokens no se imprimen, no se incluyen en capturas y no se adjuntan como evidencia.
- La prueba G6 debe escanear toda la historia, no solo el árbol actual.

8. Resiliencia e integración

Escenario	Procedimiento	Criterio de aprobación	Evidencia
Broker caído	Detener broker; ejecutar operación; restaurar	Operación consistente; Outbox conserva y reintenta; sin pérdida	DB outbox + logs sin secretos
Servicio externo caído	Simular timeout >5 s	Timeout 5 s, retry acotado/circuit breaker/fallback	Métricas + respuesta
Duplicado	Entregar mismo eventId dos veces	Una mutación; Inbox deduplica	Inbox + entidad
Mensaje inválido	data fuera de schema	NACK requeue=false; reintentos Core; DLQ	eventId + panel
Transacción fallida	Fallar persistencia después del cambio	Rollback total o compensación; Outbox coherente	DB antes/después
Idempotency-Key	Repetir POST con misma clave	Un recurso y misma respuesta	HTTP + DB
ETag	Actualizar con versión obsoleta	412 Precondition Failed	HTTP

Core informado: maxAttempts=4 cuenta entregas; con el default hay entrega original + 3 reintentos, esperas 5 s, 30 s y 2 min (ventana 2 min 35 s). Verificar siempre la topología real antes de la prueba.

9. Guion de prueba en vivo

Tiempo	Acción
00:00–02:00	Mostrar tag/CI/secret scan y arrancar desde clon limpio con un comando.
02:00–04:00	Login por rol; crear/presentar/aprobar proyecto.
04:00–07:00	Crear OT; programar; iniciar; completar; reabrir; completar; validar.
07:00–09:00	Caso negativo aleatorio: 401/403/400/404/409; demostrar ausencia de mutación.
09:00–12:00	Detener broker/externo; ejecutar escenario; restaurar; mostrar Outbox/Inbox y recuperación.
12:00–14:00	Duplicado y mensaje inválido → DLQ/reproceso; registrar eventId.
14:00–16:00	Mostrar Sonar, JaCoCo, mutación, E2E, k6, ZAP, SCA, axe/Lighthouse.
16:00–18:00	Caso al azar del profesor y defensa individual de decisiones.

Plan B permitido

El plan B solo conserva evidencia para diagnosticar; no reemplaza la demo en vivo. Si falla un servicio, se muestra el fallo, el comportamiento resiliente y la recuperación. Nunca se cambia de versión ni se oculta el incidente durante la defensa.

10. Declaración de uso de IA

Herramienta/versión	Uso	Prompt o referencia	Aceptado/corregido	Verificación humana
Codex (modelo de la sesión)	Auditoría, propuesta de CI, casos y documento	Historial de trabajo del 03/11/2026	Se aceptaron estructuras; resultados se verificaron	QA/DevOps revisa líneas, métricas y

			por comandos	enlaces
Completar por integrante	Código/tests/documentación	URL o extracto	Detallar cambios	Firma/revisor

Ejemplo de sugerencia incorrecta de IA

La IA podría afirmar que “tener 105 pruebas implica cumplir Testing”. Se rechazó: el criterio exige además cobertura, mutación, integración real, E2E, seguridad, resiliencia, performance, trazabilidad y evidencia. La corrección fue separar resultados locales de pendientes eliminatorios.

Reglas de revisión

- Todo test o código generado por IA tiene autor/revisor humano y resultado reproducible.
- No se aceptan resultados narrados sin reporte o comando verificable.
- No se suministran secretos, tokens ni datos personales a herramientas de IA.

11. Lecciones aprendidas

Defecto tardío	Por qué no se detectó antes	Prueba preventiva
CORS bloqueó login desde el Front aunque API directa daba 200	Smoke API sin header Origin	E2E por proxy con Origin real en CI/Test
Flujo de OT dependía de window.prompt y no era automatizable/usable	Pruebas centradas en endpoints y navegador parcial	E2E completo por rol + accesibilidad
Contratos de eventos divergieron en nombres/UUID/schema	No había validación cruzada ni Core bilateral	Contract tests + registro schema + prueba eventId E2E

12. Checklist final del QA

- ☐ Ejecutar clon limpio cronometrado y guardar salida completa.
- ☐ Fusionar PR finales; confirmar CI verde; escanear historia; crear tag v1.0-testing sobre main.
- ☐ Completar Jira: casos, defectos, HU, responsables, severidad, estado y evidencia.
- ☐ Ejecutar/adjuntar Sonar, mutación, Testcontainers, E2E, k6, ZAP, SCA, Gitleaks, axe y Lighthouse.
- ☐ Actualizar resultados de este PDF sin ocultar fallos; verificar 0 Blocker/Critical y ≤3 Major con workaround.
- ☐ Completar y firmar declaración de IA por integrante.
- ☐ Cargar un solo PDF Clase15_Grupo5_ObrasPublicas_Testing.pdf y sus links en Teams antes de 13:30.
- ☐ Ensayar defensa individual y demo en vivo; preparar caso al azar y recuperación de fallos.

13. Índice de evidencias a completar

Evidencia	Enlace / ruta	Responsable	Estado
Tag y commit	COMPLETAR	DevOps	Pendiente
CI Front	https://github.com/NadineLewit/DesarrolloAppsII_Front/pull/14	DevOps	PASS / fusionado
CI Back	https://github.com/ignacionogue/DesarrolloDeAplicacionesIIBack/pull/15	DevOps	PASS / fusionado
CI TPO/tag	COMPLETAR	DevOps	Pendiente
Jira	COMPLETAR	QA/PM	Pendiente
Sonar/JaCoCo/Mutación	COMPLETAR	Back	Pendiente parcial
E2E/axe/Lighthouse	COMPLETAR	Front/QA	Pendiente
k6/ZAP/SCA/Gitleaks	COMPLETAR	QA/DevOps	Pendiente
Core/RabbitMQ bilateral	COMPLETAR eventId/correlationId	Back/DevOps	Pendiente
Video/capturas/logs	COMPLETAR	QA	Pendiente

Conclusión: El equipo tiene una base verificable de tests y cobertura, pero aún no satisface todos los criterios eliminatorios. La entrega se considera lista únicamente cuando este checklist quede respaldado por evidencias del commit etiquetado.